

Remote Code Execution

Faze 1 i 2 su uspešno završene. Sada kada imamo admin cookie možemo preći u finalnu fazu napada. Koristićemo admin cookie kako bismo uploadovali PHP kod na server kako bi pristupili sistemu.

```
$illegal_ext =  
Array("php","pht","phtm","phtml","phpt","pgif","phps","php2","php3","php4","php5","php6","  
php7","php16","inc");
```

Od svih ovih ekstenzija, nema .phar ekstenzije, koja takođe može sadržati php kod. Dodaćemo .phar umesto .php i zaobići ovu proveru.

<http://localhost:8000/images/yzManchO.phar>

```
$is_check = getimagesize($_FILES['image']['tmp_name']);
```

Ovu proveru smo zaobišli tako što smo hardkodovali GIF87a na početak slike. Server gleda ovo i kaže da je slika validna, uopšte nije proverio ostatak.

Kada posetimo ovu adresu (sliku koju smo okačili), na stranici nalazimo GIF87a tekst. Znači da smo uspešno okačili sliku.

PHP Payload koji smo poslali je otvorio shell za server sa naše mašine. Ovo nam omogućava potpunu kontrolu nad mašinom.